

Firmware 7.15 Stack 10 — local audit in progress

This report freezes the pre-integration block 10 evidence. The current combined result is in 715-08-10-integration-20260927.md.

Status: block 10's focused contract passes on a provisional block 8 base. Broad host verification passes; final block 8/9 integration remains pending. No Copilot request is authorized or sent by this agent; no release acceptance is claimed.

1. Identity and frozen scope

Owner: Codex agent3, 2026-09-27. Isolated repository /private/tmp/kk715-stack10-agent3, branch audit/715-stack10-agent3-20260927. Historical code-bearing PR: <https://github.com/BitHighlander/keepkey-firmware/pull/840>. Historical base: d0c1a7c810107b1ce0a2c885a8f8ca875944a882. Historical source: 568ee5cb1b937ed866652803c5c678a76aeff6ea. Provisional current base: 5037e7f24cd68f11a1815be7a77a2aeae06022d7. Local implementation commit: 7e9fd56c6a0256e48fc0b1166d520c87cd1eb0cb.

Dependency	Immutable pin
code-signing-keys	a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec
deps/crypto/trezor-firmware	8a392f70a5d5575ece3dfb35f115d4a4b27f497c
deps/device-protocol	5fec9e6906a340be5eb3d795ec746769065b2db8
deps/googletest	7888184f28509dba839e3683409443e0b5bb8948
deps/python-keepkey	d9a02d981ee43fe3e80b28ba02466670e6e8409d
deps/qrenc/QR-Code-generator	6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8
deps/sca-hardening/SecAESSTM32	71d356a1141624994cf613bd2d2583892e8e6d5a

This commit is code-bearing and includes implementation, tests and CI wiring. It is not yet a final adjacent block 9-to-10 PR. Agent1 owns block 8 and agent2 owns block 9; their completed, immutable handoffs must be integrated and audited. The historical PR still describes the old stack and is not this candidate. Neither the canonical release branch nor fork develop was modified.

Selected contract: canonical unknown ERC20 transfer/finite approval review names the actual token contract and counterparty and displays the exact unsigned 256-bit raw amount in base units, without claiming trusted token decimals or symbol. Account-transfer routing cannot suppress that review. Unlimited approvals remain refused, and unknown contract data still requires AdvancedMode and the complete raw-data commitment. Existing nested fixed/dynamic EIP-712 array dimensions remain enforced in outermost-first order.

Noncanonical/split/trailing transfer calldata stays on the existing AdvancedMode raw-data fallback, or is refused for account-transfer routing. This block does not claim semantic ERC20 decoding of arbitrary calldata, change the trusted metadata policy, enable deferred ERC-7730 capabilities, or redesign storage. Physical-device OLED/signing, assembled release acceptance and promotion remain separate gates.

2. Git inventory and source reconciliation

The seven historical paths are individually reconciled in 715-10-reconciliation-20260927.json. The historical array source repair is superseded by the predecessor's array_levels implementation and schema guards; no array implementation is replaced. Four historical Ethereum tests were already present. All 74 predecessor test identities in the two touched suites remain; four tests are added. Two previous placeholder assertions are migrated to mandatory raw review while preserving the high-chain and pseudo-address non-alias contract. Other predecessor test bodies and build registrations are unchanged.

The retained disclosure helper formats both addresses from the signed request, converts the full 32-byte ABI amount at zero decimals, and rejects truncation. The signing confirmation buffer matches the renderer capacity via a compile check. Unknown account transfers retain needs_confirm; known/native transfers retain the existing account review. The replay's general formatting-failure fallback is narrowed to unknown ERC20 transfers so unrelated format errors still fail closed. CI removes the two capability skips only after the affected host modules execute and adds the dedicated Stack 10 wire suite to both variants.

Reproduce the current code inventory with immutable range: git diff --numstat 5037e7f24cd68f11a1815be7a77a2aeae06022d7..7e9fd56c6a0256e48fc0b1166d520c87cd1eb0cb. This is the implementation inventory; the final report/PDF/evidence inventory will be frozen after predecessor integration. It is not yet final PR inventory.

Added	Deleted	Path
1	1	.github/workflows/ci.yml
73	0	docs/release/audit-units/715-10-intake-20260927.md
4	0	include/keepkey/firmware/ethereum.h
53	13	lib/firmware/ethereum.c
16	9	lib/firmware/fsm_msg_ethereum.h
7	0	scripts/emulator/python-keepkey-tests.sh
141	0	scripts/emulator/test_stack10_regressions.py
64	0	unittests/firmware/eip712_stream.cpp
110	6	unittests/firmware/ethereum.cpp

3. Findings and security closure

ID	Property and origin	Disposition and evidence
B10-001	Existing unknown-token amount-only placeholder omits exact amount and contract, including account-transfer routing. Observer: device user; source: host transaction; full build; confirmation before signature.	Implemented. Exact formatter boundary assertions and seven actual wire contracts cover raw amount, identity substitution, account binding, equivalent zero values, fallback, every-page cancellation/retry, unlimited refusal and policy denial. Bitcoin-only excludes the EVM engine.
B10-002	Historical replay permits every amount-format failure to fall through, although only unknown-token review requires fallback.	Restricted to unknown ERC20 transfer classification. Native/known transfer checks retained; other formatting failures return compilation error. No exploit or historical shipping regression is asserted.
B10-003	Historical array dimensions were checked in written order and omitted inner constraints.	Already repaired by predecessor; implementation preserved. Added historical outer/inner fixed and mixed dynamic tests pass alongside the predecessor's schema/bounds tests. Python client dimension order matches firmware.
INT-09-001	Provisional agent2 block 9 lacks earlier numeric parsing/counter-width hardening from 2e429b6d7559722163b5f068a0a2836a9cdcd484.	Pending final-source reconciliation. Do not judge an unfinished tree as the final handoff or overwrite agent2's work.

Security contract: allowed outputs are the exact transaction facts, public addresses, and a signature only after all required confirmations. Forbidden outputs are a misleading trusted symbol/scale, a signature following rejection, or a signature after unlimited approval refusal. Unknown token identity is bound to the transaction target, not to a host label. No new secret output is introduced. Shared derived-node and signing/preload cleanup are retained.

Falsification: an isolated container overlay disables only the new unknown-token signing review while retaining the helper and tests. Five wire tests fail: contract substitution, exact values, account-transfer disclosure and both predecessor first-frame OLED assertions. The restored production source passes. Padded native-zero representations preserve review and signature; dirty ABI addresses, split prefixes and trailing data retain AdvancedMode/raw review. The maximum finite approval is cancelled on every page, each followed by a successful identical-signature retry. An unlimited allowance is refused before any button. Formatter buffers at exact size minus NUL, one byte and zero bytes fail; null pointers, short/long calldata, dirty address padding and short target addresses fail. The independent decimal oracle is uint256 maximum minus one.

4. Verification and artifact identity

Check	Result	Limits
Full native	661 firmware, 19 board, 18 crypto pass	Fresh isolated flash; 72 Zcash tests are part of firmware count.
Bitcoin-only native	135 firmware, 19 board, 18 crypto pass	Ethereum tests excluded with their implementation.
Focused wire	38 pass, zero skips	Seven new contracts plus three existing host modules; pinned Python d9a02d981ee43fe3e80b28ba02466670e6e8409d.
Negative overlay	5 expected failures, 31 passes	Source mutation and logs retained separately from positive evidence.
ARM/SRAM	Both links and budget gates pass	Full reserve 17,800 B; largest frame 7,664 B.
Initial preflight	All Stage-1 mirrors pass	Repeat after final edits before any push.
Broad full host	827 passed, 89 skipped	All owned EVM contracts execute; complete skip ledger retained.
Broad Bitcoin-only host	354 passed, 562 skipped	EVM cases deliberately skip after explicit variant verification.
OLED maximum finite approval	Inspected all three amount-review pages, fee and data-hash screens	Eight captures include duplicate captures of the three approval pages; five unique screens. Both complete addresses and all 78 amount digits are visible.
Final integration	Pending	No current-head hosted CI or physical-device validation claimed.

Raw evidence is in /private/tmp/kk715-stack10-evidence. The firmware build image is sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2. The builds ran against the working source later committed as 7e9fd56c6; their compiled version label reflects the earlier base. They are local code-equivalent evidence, not an exact-head hosted workflow. Final integrated artifacts must bind their own source and dependency identities.

Initial attempts recorded in the execution transcript (the first build log was reused): Docker HTTP 500 after host disk exhaustion; restart restored the engine. The first invocation used unavailable bash; subsequent runs use /bin/sh. Missing nested pinned token lists caused the first build to fail and were initialized before qualification. Two initial native failures were the documented obsolete placeholder assertions. Host Pillow installation needed jpeg/zlib development headers. No test was weakened to hide those errors.

5. Render and local preflight

Report source drafted; final PDF, complete inventory, artifact manifest, preflight and live predecessor identity check pending. The final report must include its own evidence/report paths. Current code whitespace and compile format checks pass. Review of changed source, callers, removed assertions, variant guards, Python defaults and equivalent inputs is documented above; final combined block 8/9 inspection remains open.

6. Independent status and external checkpoint

Implementation: complete for the isolated block 10 change. Targeted verification and adversarial disclosure checks: passed. Broad local integration on the provisional base: passed. Final predecessor integration: pending. Finding disposition: own block findings addressed; INT-09-001 pending final reconciliation. External review: no request, expressly unauthorized. Release acceptance, physical device, merge and promotion: not performed. Local readiness does not grant permission to request Copilot.